An Explainable Phishing Risk Analyzer: Comparative Evaluation of Traditional Machine Learning and Transformer-Based Approaches

Abstract— Phishing emails remain a cybersecurity threat because attackers use deceptive messages, impersonation and malicious links to obtain sensitive user information. This research presents an Explainable Phishing Risk Analyzer that investigates multiple machine learning approaches for phishing email classification. A combined dataset of 82,486 email records was collected from six sources. Deduplicated to obtain 81,890 unique emails. Four classification approaches were evaluated: TF-IDF with Linear Support Vector Machine (SVM) TF-IDF with Logistic Regression, fine-tuned DistilBERT and URL-only Logistic Regression. All models were evaluated on a held-out test set of 8,189 emails. TF-IDF with Linear SVM achieved the F1-score of 99.45% followed by DistilBERT at 99.35%. The URL-only classifier achieved an F1-score of 72.54% indicating the limitations of relying on URL information in this experiment. The project also investigates word-occlusion, rule-based explanation techniques. However explanation quality has not yet been quantitatively evaluated. The findings demonstrate the effectiveness of text-based classification on the evaluated dataset while highlighting the need for testing, on data sources and independently evaluating explanation reliability.

Keywords— Phishing Detection, Machine Learning, Deep Learning, DistilBERT Explainable Artificial Intelligence, Email Security.

1. Introduction

Phishing attacks are cyber attacks in which hackers send fake emails and messages to trick people into giving away sensitive information such as passwords and financial information among others. Note that even with the improvements in the email security systems, phishing is still a serious issue in the cybersecurity arena due to language changes by the hackers amongst others.

Typical phishing detection solutions are based on predefined rules, blacklists, sender details, and URLs. These solutions detect phishing attacks through previously known attacks; however, they will fail to recognize new phishing attacks and altered attacks, especially those disguised as normal messages. Machine learning is another approach

that uses previous classified email data for learning and then predicts if the email message is legitimate or phishing.

There exist a variety of approaches for classifying emails which include using text-based machine learning algorithms like TF-IDF with Logistic Regression and SVMs. However, more recent language models such as BERT and DistilBERT allow machines to learn context relationships in a text rather than focusing solely on individual words or frequencies of use.

High classification accuracy is not the only factor that can guarantee the efficiency and reliability of the phishing detection systems; the need to understand the reasons behind the email's suspicious classification can be another important aspect of such a process. Explainable artificial intelligence can become the answer to this challenge.

This paper presents an Explainable Phishing Risk Analyzer that investigates the effectiveness of different machine learning approaches for phishing email detection. The proposed study compares traditional TF-IDF-based classifiers with a fine-tuned DistilBERT transformer model and an independent URL-only classification approach. Unlike studies that focus primarily on comparing classification algorithms, this work also examines explanation techniques and URL-related risk indicators to investigate how model predictions can be interpreted.

The experiments use a deduplicated dataset of 81,890 emails collected from six different sources. The models are evaluated using a common held-out test set and multiple performance measures, including accuracy, precision, recall, F1-score, PR-AUC and ROC-AUC. The study aims to compare classification performance while identifying the limitations of the experimental setup and opportunities for further research.

The main contributions of this study are:

A comparative evaluation of traditional machine learning and transformer-based approaches for phishing email classification.

Preparation and evaluation of a deduplicated dataset containing 81,890 emails collected from six sources.

Investigation of word-occlusion, counterfactual and rule-based techniques for examining model predictions.

Evaluation of a URL-only classification baseline to study the contribution and limitations of URL information in phishing detection.

2. Literature Review

2.1 Traditional Machine Learning Techniques

Traditional phishing detection systems that used machine learning often relied on hand-crafted features and statistical representation of the text. The TF-IDF approach is a widely used way of representing the emails' text in numeric form.

The algorithms such as Logistic Regression and SVMs would be capable of detecting the patterns that are particular only for phishing and legitimate emails. Such algorithms are computationally inexpensive and can function well for structured text-classification tasks. However, the results produced by such algorithms may largely depend upon feature selection and quality of training data set.

Previous research has demonstrated the effectiveness of traditional machine learning techniques in phishing email detection. Rathee and Mann [1] presented a survey of machine learning and deep learning approaches, discussing classifiers such as Support Vector Machines, Logistic Regression, Random Forest and Naive Bayes. Their review also examined feature-based approaches that use email headers, message content and URL characteristics. The study highlighted the importance of selecting suitable features and evaluating detection methods based on their classification performance and limitations.

2.2 Deep Learning and Transformer-Based Detection

The use of deep learning methods made it possible for classification algorithms to detect complicated patterns within text data. Transformers [3] came up with the idea of using attention to detect the relations between words in the sequence.

The algorithm BERT (Bidirectional Encoder Representations from Transformers) [4] uses the bidirectional representations of the text in order to understand the language.

DistilBERT [5] is a more compact version of BERT that uses less computational power but still captures most of its language understanding capabilities.

Paradkar [2] conducted a comparative experimental study of machine learning and deep learning approaches for phishing email classification. The study evaluated Logistic Regression, Naive Bayes, Decision Tree, Support Vector Machine, LSTM, Bi-LSTM and CNN using an email dataset containing 20,000 records. Among the evaluated models, CNN achieved a testing accuracy of 98.05%, while Bi-LSTM achieved 98.04%. The study demonstrated the potential of deep learning approaches for email classification. However, it did not investigate transformer-based models such as DistilBERT, which are considered in the present work.

By using such methods, one has been able to determine whether emails are phishing or not by analyzing the linguistic context of the messages rather than just by keyword analysis. Such algorithms require higher computer power and cannot be explained without additional research.

2.3 Phishing Detection Based on URLs

The URL is an essential criterion for determining phishing emails as the attackers often use fake domains, strange paths, and deceptive links to lead users to the malicious site. URL detection techniques examine features including URL length, presence of special characters, domain, and other URL attributes.

Despite being helpful in security classification, URL detection has disadvantages in case of its sole application. A phishing email could have a valid-looking URL, whereas legitimate emails might have weird URLs. That is why URL classification can be used in addition to text classification, but not as the only solution.

Rathee and Mann [1] discussed URL-based phishing detection approaches and highlighted limitations associated with relying exclusively on URL characteristics. Attackers may use shortened or obfuscated links to make malicious URLs appear legitimate. URL-based approaches may therefore fail to identify certain attacks or

incorrectly classify legitimate links. This motivates evaluating URL information separately alongside full email text classification in the present study.

2.4 Explainable Artificial Intelligence for Cybersecurity

ML models are able to generate highly accurate predictions without explaining the logic of the process to the user. Such a lack of explainability may decrease trust, especially when dealing with cybersecurity where understanding potential threats is vital.

Explainable AI tools are intended to deliver some information about a model's functioning. Word-occlusion techniques focus on determining how the deletion of a single word influences prediction results, while counterfactual explanations look at how variations in the input data might change predictions of the model. Related model-agnostic methods such as LIME [6] and SHAP [7] also explain individual predictions by examining how changes to the input affect the output.

Those tools can allow users and analysts to analyze factors which influence the result of classification. Nevertheless, such explanations should be assessed since the intelligible explanation does not guarantee that it really represents the logic of the process.

2.5 Research Gap

The current methods of detecting phishing attacks offer valuable solutions using conventional machine learning, deep learning, and URL-based techniques. Nevertheless, there are some problems that should be overcome:

Conventional text classifiers may fail to capture contextual language interactions.
The transformer architecture is computationally expensive and hard to interpret.
URL-based approach does not consider the context of the email message.
Good classification performance does not guarantee clear explanations and reliable risk analysis.

Although previous studies have investigated traditional machine learning, recurrent neural networks and convolutional neural networks for phishing email detection [1], [2], further evaluation of transformer-based approaches and their comparison with traditional text classifiers remains valuable. In addition, classification performance alone does not establish whether model predictions can be reliably interpreted.

The present study addresses these areas by comparing TF-IDF-based classifiers, a fine-tuned DistilBERT model and a URL-only baseline using a deduplicated dataset collected from six sources. It also investigates word-occlusion, counterfactual and rule-based explanation techniques. Unlike a general claim of explainability, this study distinguishes classification performance from explanation quality, which remains an area for further quantitative evaluation.

Table I. Comparison of Related Research

Research	Approaches	Main focus
Rathee and Mann (2022) [1]	ML, LSTM, Bi-LSTM, CNN, URL-based methods	Survey of phishing detection research
Paradkar (2023) [2]	SVM, LR, NB, DT, LSTM, Bi-LSTM, CNN	Experimental comparison
Present study	SVM, LR, DistilBERT, URL-only LR	Multi-source evaluation and explanation investigation

Table I summarizes the relationship between the reviewed studies and the present work. While previous research examined traditional machine learning and deep learning approaches, this study extends the comparison to a transformer-based classifier and investigates explanation techniques alongside classification performance.

3. Methodology

3.1 Dataset and Preprocessing

The combined dataset contained 82,486 email records initially. Each email was labeled with binary labels of 1 (phishing) and 0 (legitimate emails).

We transformed the e-mail text to lower case and removed extra spaces before the training. Next we identified duplicate emails and removed 596 records (0.72%) leaving us with 81,890 unique emails . We did not find duplicate emails with conflicting labels. But emails with slight modifications to the text may remain, since only exact duplicates were removed.

The cleaned dataset was divided into training, validation and test sets using the stratified splitting according to the source and class labels. Random state: 42.

The training set contains 65,512 emails (80%) and the validation and test set each contain 8,189 emails (10%). We also checked that no identical cleaned email appeared in multiple sets. This helps prevent repeated emails from affecting the evaluation results.

Since all six sources are present in each set, the model is evaluated on data from sources it has already seen during training.

3.2 Models and Experimental Setup

We selected four classification models to detect phishing emails. These are traditional models for machine learning, a transformer based model and a URL based approach.

1. Linear SVM + TF-IDF: First, we converted the email text into numerical features using TF-IDF (Term Frequency–Inverse Document Frequency). It gives words importance according to their frequency in an email and their commonality across the dataset. These features are then used to classify emails as phishing or legitimate using a Linear Support Vector Machine (SVM). The SVM finds the best boundary between the two classes.

2. TF-IDF plus Logistic Regression: This model uses TF-IDF to turn text into numbers. Then it uses Logistic Regression to classify the text. It gives a probability that an email's, in one class or the other. Its coefficients can also be examined to understand which features influence the prediction.

For both TF-IDF models, the vectorizer and classifier were fitted using only the training data, while the validation set was used for model selection.

3. DistilBERT: We used the pretrained distilbert-base-uncased model for email classification. Unlike traditional machine learning models, DistilBERT can understand the context of words, which helps it analyse email messages. The model was fine-tuned on our email dataset using the settings in Table II.

Table II. DistilBERT Training Configuration

Parameter	Value
Pretrained model	distilbert-base-uncased
Maximum sequence length	256
Epochs	2
Learning rate	2×10^{-5}
Training batch size	16
Evaluation batch size	32
Weight decay	0.01
Warmup ratio	0.06
Checkpoint selection	Validation F1

The maximum input length was set to 256 tokens. Therefore, longer emails are truncated, and the remaining text is not considered during prediction. The fine-tuned model was saved separately from the original pretrained model.

4. URL only Logistic Regression: this model looks at just the URLs in the email. It extracts features from the URLs and uses Logistic Regression to classify them. It makes no use of any external threat intelligence databases, no use of live reputation services and no use of actual webpage inspection. The aim is to see how much information you can get from the URLs alone for the purposes of phishing detection.

We tested all four models on the same set of 8,189 emails in order to be able to compare them fairly. To assess how well the models performed we used a range of metrics including accuracy, precision, recall, F1-score, PR-AUC, ROC-AUC and confusion matrices.

We didn't just go with accuracy as both a false negative (i.e. missing a phishing email) and a false positive (i.e. labelling a legitimate email as phishing) can be problematic.

3.3 Proposed System Architecture

The proposed Explainable Phishing Risk Analyzer aims to detect suspicious emails and help users understand why an email may be risky.

The system has five main stages: email input, preprocessing, classification, explanation generation and risk presentation (Fig. 1).

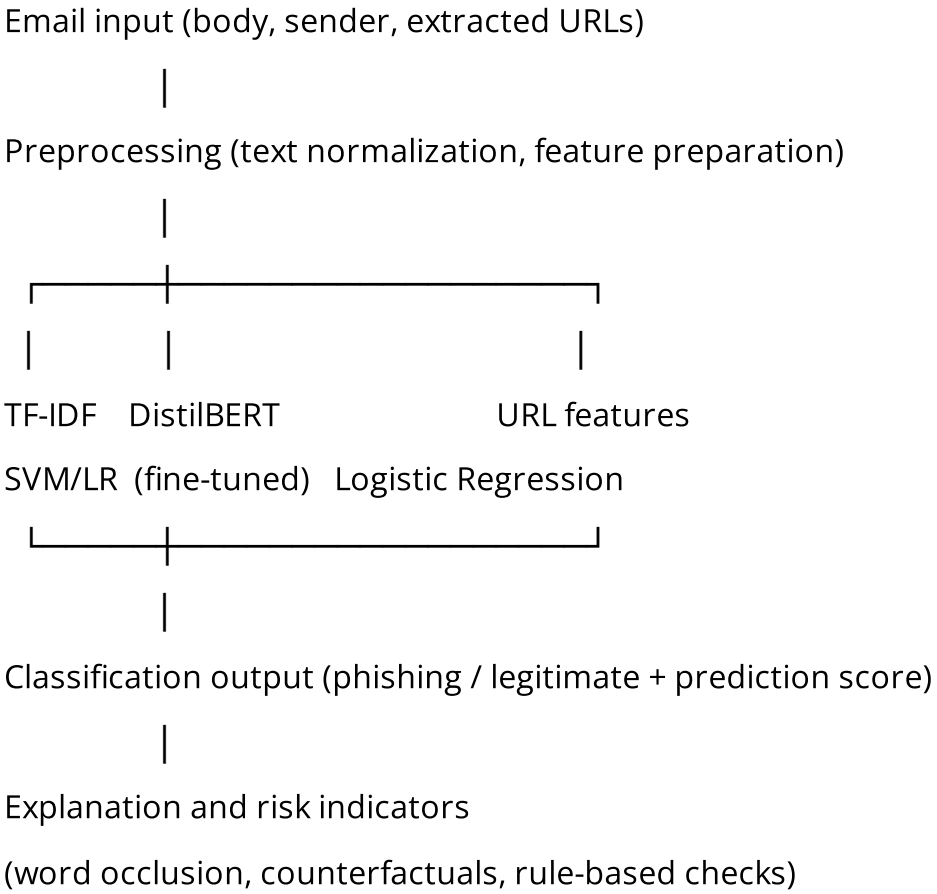


Fig 1. Architecture of the system. The three classifiers are evaluated individually (i.e. their predictions are not combined).

The system then gets an email (which will contain the body of the message and occasionally the sender and URL information). It then goes through a pre-processing

stage to clean the text and convert it into the required format (e.g. TF-IDF features, DistilBERT tokens, URL features etc).

Then the classification stage decides whether the email in question is phishing or genuine.

The system separates three main functions:

Classification: determines whether an email is phishing or genuine and provides a score for that determination.
Explanation: The system has highlighted the parts of the email which may have had an effect on the prediction.

For generating explanations, the proposed system considers three methods:

Word Occlusion: looks at how the prediction changes when selected words are either removed or altered.
Counterfactual analysis: does changing specific elements of the email change the predicted class?
Rule based indicators: look for the oddities, the suspicious bits (e.g. an odd URL, odd sender info) using a set of rules.

These techniques give the user some extra information but don't in any way prove that the email is malicious. We have not performed a separate quantitative evaluation of explanation quality or reliability. Therefore, the current experimental results focus only on classification performance.

3.4 Limitations of the Experimental Design

We used separate training, validation and test sets to evaluate the models. Duplicate emails were removed before splitting, and we checked for identical text across the three sets.

However, our experimental setup has some limitations. Since all six email sources are included in every set, the results do not show how well the models would perform on completely new email sources. Also, phishing techniques keep changing, so models trained on the existing data may not perform equally well against newer attacks.

In future work, we can improve the evaluation by testing the models on unseen email sources and checking their performance against modified or more advanced phishing messages.

4. Results and Discussion

4.1 Model Comparison

All four of the classification models were evaluated on the same held out test set (8,189 emails). The results are in Table III with accuracy, precision, recall, F1-score, PR-AUC and ROC-AUC. TF-IDF with Linear SVM comes out on top with the highest F1-score of 99.45%, DistilBERT at 99.35%. The difference in F1-score is very small, DistilBERT just edging out in both PR-AUC and ROC-AUC. So both approaches perform very well on this dataset, there's no real statistical difference between them.

Table III. Performance of the four phishing email classifiers on the test set

Model	Accuracy (%)	Precision (%)	Recall (%)	F1 (%)	PR-AUC	ROC-AUC
TF-IDF & Linear SVM	99.43	99.39	99.51	99.45	0.999819	0.999800
DistilBERT	99.33	99.44	99.27	99.35	0.999831	0.999816
TF-IDF & Logistic Reg.	98.83	98.65	99.11	98.88	0.999193	0.999137
URL only Log Reg.	62.02	58.17	96.32	72.54	0.642802	0.663234

A notable observation is that a simple TF-IDF model matched a fine-tuned transformer on this dataset. Logistic Regression performed a little lower but remained strong with an F1 of 98.88 percent.

The URL-only model performed worse. It had a recall of 96.32 percent but a low precision of only 58.17 percent, which meant many legitimate emails were flagged as phishing. This

occurs because URLs alone provide little information. Many real emails contain links that appear suspicious at first glance, yet the model cannot see the surrounding text. Full-text models can use that surrounding wording, which explains why they performed better.

4.2 Limitations and Future Work

The experimental results should be interpreted in the context of several limitations. First, although duplicate email texts were removed before splitting, the dataset was divided using stratified random sampling. Consequently, all six sources were represented in the training, validation and test sets. The evaluation therefore does not establish the models' ability to generalize to entirely unseen email sources.

Secondly, the analysis is carried out with respect to the classification results and no additional evaluation of the quality of explanation provided is considered separately. Even though the word occlusion, counterfactual, and rule-based approaches are investigated, their stability, faithfulness, and effectiveness require evaluation.

Third, the URL-only classifier uses URLs extracted from email content without external threat-intelligence services, live reputation checks or webpage inspection. Its results should therefore be interpreted as the performance of a URL-based baseline rather than a complete URL security system.

Future work will include source-held-out evaluation, testing on emails from different time periods, robustness testing against adversarially modified messages and quantitative evaluation of explanation reliability. Additional threshold-based analysis may also help understand the trade-off between false positives and false negatives.

5. Conclusion

The proposed paper included a comparative study of four different algorithms used for classifying the emails to detect any phishing activity. The F1-score of the algorithm that utilized the combination of TF-IDF and Linear SVM was 99.45% which was the highest. The F1-score of DistilBERT that was fine-tuned was 99.35% which was almost on par with the previous one.

The results indicate that full email text provided stronger classification performance than URL-only information in the evaluated experiment. However, the high scores obtained from a random stratified split do not establish generalization to unseen email sources or future phishing attacks.

The study also investigates explanation techniques to support the interpretation of model predictions. Since explanation quality has not been quantitatively evaluated, further research is necessary to establish their reliability. Future work will focus on unseen-source testing, temporal evaluation, robustness analysis and systematic evaluation of explanation quality.

References

[1] D. Rathee and S. Mann, “Detection of E-Mail Phishing Attacks – Using Machine Learning and Deep Learning,” International Journal of Computer Applications, vol. 183, no. 47, Jan. 2022.

[2] N. S. Paradkar, “Phishing Email’s Detection Using Machine Learning and Deep Learning,” in 2023 3rd International Conference on Advances in Computing, Communication, Embedded and Secure Systems (ACCESS), 2023, doi: 10.1109/ACCESS57397.2023.10200493.